CRISC Domain C - 100 More Very Hard Questions

Risk Response and Reporting - Expert Level (Part 2)

CRISC Mastery Series

October 21, 2026

Outline

1. 1. Risk Response Strategies - Advanced
2. 2. Risk and Control Ownership - Advanced
3. 3. Third-Party Risk Management - Advanced
4. 4. Control Design and Implementation - Advanced
5. 5. Monitoring and Reporting - Advanced
6. 6. Advanced Scenarios

Q101: Risk Response Combination Trap

Question

A company faces a $3M risk from ransomware. They implement:

- Backups costing $200K (reduces impact to $500K)
- Cyber insurance costing $150K (covers $1M)
- Employee training costing $50K (reduces likelihood by 40%)

What is the NET risk exposure after all controls?

A. $0
B. $500K
C. $250K (after insurance covers $250K of remaining)
D. $1.5M

Q101: Explanation

Correct Answer: C

Calculation:

- Original risk: $3M
- After backups: $500K impact (but likelihood reduced by training)
- Training reduces likelihood 40%: $500K $\times$ 60% = $300K expected loss
- Insurance covers $1M: covers remaining $300K
- Net exposure: $0 financial, but reputational risk remains

Critical Trap

Multiple controls compound. Calculate sequentially, not additively.

Q102: Risk Avoidance Hidden Cost Trap

Question

A company avoids a risk by not entering a new market. What hidden risk does this create?

- A No hidden risk - avoidance is complete
- B Opportunity cost and competitive disadvantage
- C Increased regulatory scrutiny
- D Higher insurance premiums

Q102: Explanation

Correct Answer: B

Avoidance creates opportunity cost risk:

- Lost revenue from not entering market
- Competitors may gain advantage
- Shareholders may question strategy
- Avoidance is not "free" - it has costs

Critical Trap

Avoidance = Eliminates one risk but creates opportunity cost risk.

Q103: Transfer of Unknown Risk

Question

An organization purchases cyber insurance without conducting a risk assessment. What is the PRIMARY problem?

A. Insurance is too expensive
B. Coverage may be inadequate or inappropriate
C. The insurance company may deny claims
D. Both B and C

Q103: Explanation

Correct Answer: D

Without risk assessment:

- You don't know what to insure
- Coverage limits may be wrong
- Exclusions may apply to your actual risks
- Insurer may deny claims for undisclosed risks
- Premiums may not reflect actual exposure

Critical Trap

Transfer without assessment = Blind transfer = Potential coverage gap.

Q104: Risk Acceptance Authority Escalation

Question

A business unit manager accepts a risk with $500K impact. The enterprise risk appetite is $250K. What should the risk manager do?

A. Accept the decision - BU manager has authority
B. Document the acceptance and move on
C. Escalate to senior management for approval
D. Automatically implement controls

Q104: Explanation

Correct Answer: C

Escalation is required:

- Risk exceeds enterprise appetite ($500K ¿ $250K)
- BU manager cannot unilaterally exceed appetite
- Senior management must approve
- Board may need to be informed

Critical Trap

Risk appetite is an enterprise limit, not a guideline. Exceeding it requires executive approval.

Q105: Mitigation Timing Trap

Question

A risk has 90% likelihood and $1M impact. Controls cost $100K and take 6 months to implement. What is the risk of waiting 6 months?

A. No risk - controls will be implemented

B. $450K expected loss during implementation period

C. $900K expected loss during implementation period

D. The risk will decrease over time

Q105: Explanation

Correct Answer: B

Calculation:

- Expected loss = 90% × $1M = $900K annually
- During 6 months: $900K × 0.5 = $450K
- Risk continues while controls are being implemented

Critical Trap

Implementation time = Risk exposure continues. Consider interim controls during implementation.

Q106: Residual Risk Acceptance

Question

After implementing controls, residual risk is $400K. Risk appetite is $250K. What are the options?

A. Accept residual risk - controls are implemented
B. Implement additional controls, transfer, or escalate for acceptance
C. Ignore the gap - close to appetite
D. Remove all controls and start over

Q106: Explanation

Correct Answer: B

Residual risk exceeds appetite:

- Additional controls to reduce further
- Transfer remaining risk (insurance)
- Escalate to management for formal acceptance
- Cannot simply accept without authority

Critical Trap

Residual risk ¿ Appetite = Action required. Cannot ignore the gap.

Q107: Transfer Limitation Trap

Question

A company transfers risk through outsourcing. The vendor suffers a breach. Who bears the reputational damage?

A. The vendor
B. The original company
C. Both equally
D. No one - reputational damage is transferred

Q107: Explanation

Correct Answer: B

Reputational damage remains with the original company:

- Customers blame the brand they trusted
- Media reports name the original company
- Regulatory scrutiny focuses on the data owner
- Reputation cannot be outsourced

Critical Trap

Transfer = Financial only. Reputation NEVER transfers.

Q108: Avoidance Decision Trap

Question

A company avoids a risk by terminating a product line. What must be considered before this decision?

- A Only the risk being avoided
- B The risk, opportunity cost, and stakeholder impact
- C Only the cost of termination
- D Only regulatory requirements

Q108: Explanation

Correct Answer: B

Comprehensive analysis required:

- What risk is being avoided?
- What revenue is lost?
- How are customers affected?
- What are employee impacts?
- What is the competitive impact?

Critical Trap

Avoidance is irreversible - consider all impacts before deciding.

Q109: Risk Response Timing Trap

Question

A risk is identified with 50% likelihood and $100K impact. The control costs $60K. Should the control be implemented?

A. Yes, because risk exists

B. No, because control cost exceeds expected loss

C. Yes, because 50% is high likelihood

D. Cannot be determined

Q109: Explanation

Correct Answer: B

Calculation:

- Expected loss = 50% × $100K = $50K
- Control cost = $60K
- $60K ¿ $50K = Control NOT justified
- Accept the risk (documented)

Critical Trap

Expected loss = Likelihood × Impact. Control cost ¿ Expected loss = Accept.

Q110: Risk Response Documentation Trap

Question

A risk response was implemented but not documented. What is the consequence?

A. No consequence - the risk is mitigated
B. Cannot demonstrate due care or effectiveness
C. The control automatically fails
D. The risk increases

Q110: Explanation

Correct Answer: B

Undocumented controls have limited value:

- Cannot prove control exists
- Cannot demonstrate effectiveness
- Cannot defend in audit or legal proceedings
- Knowledge is lost when personnel change

Critical Trap

Undocumented = Undefensible. Document all risk responses.

Q111: Risk Owner Conflict Resolution

Question

Two business units claim ownership of a shared risk. Neither wants to take responsibility. What should happen?

A. Split the risk 50/50

B. Assign to the BU with larger budget

C. Escalate to senior management to assign a single owner

D. The risk remains unowned

Q111: Explanation

Correct Answer: C

Escalate for single ownership:

- Shared ownership = No accountability
- Senior management can assign authority
- Owner must have cross-functional authority
- May need C-level or COO assignment

Critical Trap

Multiple owners = No owner. Single point of accountability required.

Q112: Control Owner Without Authority Trap

Question

A control owner identifies a failing control but has no budget to fix it. What should they do FIRST?

A. Document the issue and escalate to risk owner

B. Implement a compensating control themselves

C. Accept the risk and move on

D. Wait for the next audit to report

Q112: Explanation

Correct Answer: A

Escalate to risk owner:

- Risk owner has budget authority
- Risk owner is accountable
- Control owner documents the issue
- Control owner may recommend solutions

Critical Trap

Control owner not equal to Budget authority. Escalate to risk owner for resources.

Q113: Risk Owner Delegation Trap

Question

A risk owner delegates authority to a subordinate without documentation. What is the risk?

A. No risk - delegation is informal

B. Subordinate cannot be held accountable

C. Risk owner remains accountable but subordinate has no authority

D. Both B and C

Q113: Explanation

Correct Answer: D

Undocumented delegation creates issues:

- Subordinate cannot make binding decisions
- Risk owner remains accountable
- No clear authority chain
- Audit trail is broken

Critical Trap

Delegation must be documented, communicated, and bounded.

Q114: Control Owner Multiple Controls

Question

A control owner is responsible for 50 controls. What is the PRIMARY risk?

A. Too much work

B. Controls may not receive adequate attention

C. Higher salary required

D. Needs more training

Q114: Explanation

Correct Answer: B

Span of control risk:

- 50 controls is too many for one person
- Some controls will be neglected
- Testing and monitoring may be insufficient
- Effectiveness may degrade

Critical Trap

Too many controls = Diluted oversight. Consider control owner workload.

Q115: Risk Owner Out of Office

Question

A critical risk decision is needed but the risk owner is on vacation. What should happen?

- A Wait for the risk owner to return
- B The control owner can make the decision
- C A designated alternate with documented authority
- D The decision cannot be made

Q115: Explanation

Correct Answer: C

Designated alternate required:

- Risk owner should designate an alternate
- Alternate must have documented authority
- Alternate must understand the risk
- Business continuity for risk management

Critical Trap

No alternate = Decision paralysis. Always designate an alternate risk owner.

Q116: Risk Owner vs Control Owner Conflict

Question

Risk owner wants to accept risk. Control owner insists on remediation. Who decides?

A. Risk owner - they own the risk

B. Control owner - they own the control

C. Senior management - conflict requires escalation

D. Whoever has more budget

Q116: Explanation

Correct Answer: C

Escalate to senior management:

- Conflict indicates unresolved issues
- Senior management provides perspective
- Balance risk and control needs
- Document the decision

Critical Trap

Risk owner not equal to Unilateral authority. Conflicts require escalation.

Q117: Risk Owner for IT Risk

Question

Who should be the risk owner for a data breach risk?

A. CISO
B. CIO
C. Business leader who owns the data
D. IT manager

Q117: Explanation

Correct Answer: C

Business leader owns the risk:

- Data is a business asset
- Breach impacts business objectives
- Business leader has budget authority
- IT/CISO are enablers, not owners

Critical Trap

IT does NOT own business risk. Data owner = Risk owner.

Q118: Control Owner Testing Responsibility

Question

Who is responsible for testing controls?

A. Risk owner
B. Control owner
C. Internal audit
D. External auditor

Q118: Explanation

Correct Answer: B

Control owner tests controls:

- Control owner is responsible for effectiveness
- Testing verifies the control works
- Internal audit provides independent assurance
- External audit provides external assurance

Critical Trap

Control owner = First line of testing. Audit = Independent verification.

Q119: Risk Owner Budget Authority

Question

A risk owner lacks budget to implement controls. What is the consequence?

A. Nothing - controls are optional
B. Risk cannot be effectively managed
C. Control owner must pay
D. Risk is automatically transferred

Q119: Explanation

Correct Answer: B

No budget = No effective risk management:

- Controls cannot be implemented
- Risk remains unmanaged
- Risk owner is ineffective
- Escalation to higher authority needed

Critical Trap

Risk ownership requires budget authority. No budget = Not a true risk owner.

Q120: Risk Owner Rotation

Question

Should risk ownership rotate periodically?

A. Yes, for objectivity
B. No, ownership should be stable
C. Depends on organizational requirements
D. Only for IT risks

Q120: Explanation

Correct Answer: B

Risk ownership should be stable:

- Continuity of knowledge
- Accountability is maintained
- Relationships with stakeholders
- Long-term risk perspective

Critical Trap

Risk owner turnover = Loss of continuity. Stability is preferred.

Q121: Vendor Assessment Scope Trap

Question

A vendor has a SOC 2 Type II report. Can you rely on it for all services?

- A Yes, SOC 2 covers all services
- B No, only services within the report scope
- C Yes, if the report is recent
- D No, SOC 2 is not reliable

Q121: Explanation

Correct Answer: B

SOC 2 scope is limited:

- Report covers specific services
- Out-of-scope services need assessment
- Check the scope section first
- Request scope expansion if needed

Critical Trap

SOC 2 not equal to All services. Scope matters.

Q122: Fourth-Party Risk Trap

Question

Your vendor uses a subcontractor. The subcontractor has a breach. Who is liable?

A. Only the subcontractor
B. Your organization and the vendor
C. Only your organization
D. Only the vendor

Q122: Explanation

Correct Answer: B

Multiple parties liable:

- Your organization: Regulatory accountability
- Vendor: Contractual responsibility
- Subcontractor: Direct liability
- Fourth-party risk affects you

Critical Trap

Fourth-party breach = Your problem too. You cannot outsource accountability.

Q123: Vendor Offboarding Trap

Question

What is the GREATEST risk during vendor offboarding?

A. Service disruption
B. Data remanence (data not destroyed)
C. Cost of transition
D. Loss of knowledge

Q123: Explanation

Correct Answer: B

Data remanence is greatest risk:

- Data may remain on vendor systems
- Backups may not be deleted
- Regulatory violations possible
- Reputational damage if leaked

Critical Trap

Offboarding = Data destruction is 1 priority. Require certificate of destruction.

Q124: Vendor Contract Trap

Question

Which contract clause is MOST important for data protection?

A. Service level agreement
B. Right to audit and security requirements
C. Indemnification clause
D. Non-disclosure agreement

Q124: Explanation

Correct Answer: B

Right to audit + security requirements:

- Enables ongoing verification
- Establishes minimum standards
- Provides recourse if standards not met
- Financial penalties don't prevent breaches

Critical Trap

Prevention ¿ Compensation. Right to audit enables prevention.

Q125: Vendor Assessment Timing Trap

Question

When should a vendor assessment be conducted?

A. Before contract signing
B. After contract signing
C. After go-live
D. Annually only

Q125: Explanation

Correct Answer: A

Before contract signing:

- Leverage to negotiate security terms
- Informed decision about vendor
- Identify deal-breakers early
- Can require improvements before signing

Critical Trap

Assessment after contract = No leverage. Assess before signing.

Q126: Vendor Monitoring Trap

Question

How often should vendor risk be reassessed?

- A. Only at contract renewal
- B. Annually or when significant changes occur
- C. Every 3 years
- D. Only when there is a breach

Q126: Explanation

Correct Answer: B

Annual or event-driven reassessment:

- Annual review minimum
- When vendor services change
- When vendor has incident
- When regulations change
- When vendor's security posture changes

Critical Trap

Vendor risk is not static. Annual reassessment required.

Q127: Vendor Exception Management

Question

A vendor requests an exception to your security policy. What should happen?

A. Approve automatically - vendor knows best

B. Evaluate risk and require compensating controls

C. Deny all exceptions

D. Ignore the request

Q127: Explanation

Correct Answer: B

Evaluate risk and require compensating controls:

- Understand the business need
- Assess the risk of the exception
- Require compensating controls
- Document and review periodically

Critical Trap

Exceptions are not automatic. Evaluate, compensate, document.

Q128: Vendor Incident Notification

Question

How quickly should a vendor notify you of a breach?

A. Within 30 days

B. Within 24-72 hours (per contract/regulation)

C. Within 1 week

D. At their discretion

Q128: Explanation

Correct Answer: B

24-72 hours is standard:

- Regulatory requirements (GDPR: 72 hours)
- Contract should specify timeframe
- You need time to respond
- You need to notify regulators

Critical Trap

Delayed notification = Delayed response. Specify notification timeframe in contract.

Q129: Vendor Data Location Trap

Question

A vendor stores your data in a foreign country. What is the PRIMARY concern?

A. Data latency
B. Regulatory and legal jurisdiction issues
C. Higher costs
D. Language barriers

Q129: Explanation

Correct Answer: B

Jurisdictional issues:

- Data protection laws vary by country
- GDPR, CCPA may apply
- Law enforcement access differs
- Legal process may be difficult

Critical Trap

Data location = Legal jurisdiction. Know where your data is stored.

Q130: Vendor Subcontractor Approval

Question

Should a vendor be required to obtain approval before using subcontractors?

- A No, vendors can manage their own operations
- B Yes, to maintain visibility of fourth-party risk
- C Only if the subcontractor is in a different country
- D Only for critical services

Q130: Explanation

Correct Answer: B

Approval required for visibility:

- You need to know who handles your data
- Fourth-party risk must be assessed
- You may object to specific subcontractors
- Maintains chain of accountability

Critical Trap

Unknown subcontractors = Unmanaged risk. Require approval for subcontractors.

Q131: Preventive vs Deterrent Trap

Question

A warning banner on a login page is what type of control?

- A Preventive
- B Detective
- C Deterrent
- D Corrective

Q131: Explanation

Correct Answer: C

Warning banner is deterrent:

- It warns of consequences
- It doesn't block access (preventive)
- It doesn't detect intrusion (detective)
- It discourages unauthorized access through fear

Critical Trap

Warning = Deterrent. It discourages, it doesn't prevent.

Q132: Detective vs Corrective Trap

Question

An IDS detects and blocks an intrusion. Is this detective or corrective?

A. Detective only
B. Corrective only
C. Both detective and corrective
D. Preventive

Q132: Explanation

Correct Answer: C

IDS with auto-block performs both:

- Detection = Detective
- Blocking = Corrective
- Modern systems combine functions
- Analyze the actions, not the name

Critical Trap

Controls can have multiple functions. IDS with auto-block = Detective + Corrective.

Q133: Compensating Control Trap

Question

A compensating control must provide:

A. Cheaper solution

B. Equivalent or superior risk reduction

C. Automated solution

D. IT-approved solution

Q133: Explanation

Correct Answer: B

Equivalent or superior risk reduction:

- Compensating control must address the same risk
- Must reduce risk to acceptable level
- Cost is secondary
- Effectiveness is primary

Critical Trap

Compensating control = Same risk reduction, different method. Cheaper but less effective = Not acceptable.

Q134: Control Testing Frequency

Question

How often should controls be tested?

A. Annually for all controls
B. Based on risk and criticality
C. Only when changes occur
D. Quarterly for all controls

Q134: Explanation

Correct Answer: B

Risk-based testing frequency:

- High-risk controls: More frequent
- Low-risk controls: Less frequent
- Regulatory requirements may mandate
- Consider change frequency and stability

Critical Trap

One size does NOT fit all. Risk-based frequency is appropriate.

Q135: Design vs Operating Deficiency

Question

A control is designed correctly but not operating as designed. This is:

A. Design deficiency
B. Operating deficiency
C. Control gap
D. Control redundancy

Q135: Explanation

Correct Answer: B

Operating deficiency:

- Control is designed correctly
- Control is not operating effectively
- Could be due to personnel, process, or technology failure
- Remediation focuses on operation

Critical Trap

Design = Blueprint. Operating = Actual performance. Design correct, operation failing = Operating deficiency.

Q136: Parallel Changeover Risk

Question

What is the PRIMARY risk of parallel changeover?

A. System failure
B. Data inconsistency
C. User resistance
D. Higher costs

Q136: Explanation

Correct Answer: B

Data inconsistency is primary risk:

- Both systems process transactions
- Data may not sync
- Reconciliation is complex
- Errors may go undetected

Critical Trap

Parallel = Safest for availability, riskiest for data consistency.

Q137: Abrupt Changeover Appropriate

Question

When is abrupt changeover acceptable?

A. For critical systems
B. For minor changes with easy rollback
C. When users are trained
D. When vendor recommends

Q137: Explanation

Correct Answer: B

Minor changes with easy rollback:

- Low business impact
- Quick recovery possible
- No critical processes affected
- Acceptable risk level

Critical Trap

Abrupt = Fastest but highest risk. Only for non-critical, reversible changes.

Q138: Post-Implementation Review Timing

Question

When should a post-implementation review occur?

A. Immediately after go-live

B. After system has stabilized

C. Only if issues occurred

D. Before next audit

Q138: Explanation

Correct Answer: B

After stabilization (3-6 months):

- Issues have surfaced
- User feedback is meaningful
- Performance can be assessed
- Lessons learned are clear

Critical Trap

Too early = Issues haven't surfaced. Too late = Lessons forgotten. Wait for stability.

Q139: Control Automation Trap

Question

A control is automated. Does this eliminate the need for monitoring?

- A Yes, automated controls are self-monitoring
- B No, automated controls can fail
- C Yes, automation eliminates errors
- D No, but monitoring can be reduced

Q139: Explanation

Correct Answer: B

Automated controls still require monitoring:

- Automation can fail (bugs, config errors)
- Automated controls can be bypassed
- Automation logic may become outdated
- Regular testing confirms effectiveness

Critical Trap

Automated not equal to Self-monitoring. Automation reduces human error but doesn't eliminate oversight.

Q140: Control Testing Approach

Question

What is the BEST approach for control testing?

A. Test every transaction

B. Statistical sampling with documented methodology

C. Test only recent transactions

D. Rely on management assurance

Q140: Explanation

Correct Answer: B

Statistical sampling is best:

- Testing every transaction is impractical
- Sampling provides reasonable assurance
- Documented methodology enables repeatability
- Results are defensible to auditors

Critical Trap

Testing = Sampling (not 100%). Document methodology for auditability.

Q141: KRI vs KPI vs KCI Trap

Question

The percentage of employees who completed security awareness training is a:

A. KRI
B. KPI
C. KCI
D. None

Q141: Explanation

Correct Answer: B

Training completion is KPI:

- Measures performance of training program
- Backward-looking
- Doesn't predict risk (KRI)
- Doesn't measure control effectiveness (KCI)

Critical Trap

Training completion = KPI. Phishing click rate = KRI. Access review completion = KCI.

Q142: KRI Threshold Breach

Question

A KRI has breached its threshold. What should happen FIRST?

- A Escalate to senior management
- B Investigate the cause
- C Implement additional controls
- D Update the risk register

Q142: Explanation

Correct Answer: B

Investigate first:

- Is the data accurate?
- Is it a spike or a trend?
- What is the root cause?
- What response is appropriate?

Critical Trap

Threshold breach not equal to Immediate escalation. Investigate first, then respond.

Q143: Board Reporting Trap

Question

What should NOT be included in a board-level risk report?

- A Key risk indicators
- B Comparison to risk appetite
- C Technical vulnerability details
- D Recommended actions

Q143: Explanation

Correct Answer: C

Technical details should NOT be in board reports:

- Board members are not technical
- Focus on business impact
- Technical details obscure message
- Board needs strategic view

Critical Trap

Board = Business language. Technical details = Operational reports.

Q144: SMART KRI Criteria

Question

A KRI is defined as "number of security incidents." What is the weakness?

A. Not measurable

B. Lacks specificity and thresholds

C. Too difficult to track

D. Not relevant

Q144: Explanation

Correct Answer: B

Lacks specificity and thresholds:

- What type of incidents?
- What severity?
- What timeframe?
- What triggers action?

Critical Trap

Vague KRI = Useless KRI. Specific + Measurable + Threshold + Actionable.

Q145: Control Monitoring Purpose

Question

The PRIMARY purpose of control monitoring is to:

A. Verify control is working as designed
B. Verify control is effectively reducing risk
C. Verify control is cost-effective
D. Verify control is automated

Q145: Explanation

Correct Answer: B

Verify risk reduction effectiveness:

- Control working not equal to Control effective
- Design may be flawed
- Threat landscape may have changed
- Monitor effectiveness, not just operation

Critical Trap

Control working not equal to Control effective. Monitor effectiveness.

Q146: Heat Map Limitation

Question

What is the PRIMARY limitation of a risk heat map?

- A Too complex
- B Qualitative and subjective
- C Cannot show multiple risks
- D Requires too much data

Q146: Explanation

Correct Answer: B

Qualitative and subjective:

- "High" means different things
- No quantification
- Difficult to compare
- Can oversimplify

Critical Trap

Heat map = Qualitative = Subjective. Dashboards = Quantitative + Qualitative.

Q147: Exception Report Content

Question

What should an exception report include?

A. Only the exception list

B. Exception, compensating controls, owner, expiration

C. Only long-standing exceptions

D. Only IT-approved exceptions

Q147: Explanation

Correct Answer: B

Comprehensive exception reporting:

- Description of exception
- Compensating controls
- Risk owner
- Expiration date
- Business justification

Critical Trap

Exception report not equal to Simple list. Must include risk context.

Q148: KCI vs KRI

Question

The number of access reviews completed on time is a:

A. KRI
B. KPI
C. KCI
D. None

Q148: Explanation

Correct Answer: C

Access review completion is KCI:

- Access review is a control
- Completion measures control effectiveness
- Doesn't predict risk (KRI)
- Doesn't measure overall performance (KPI)

Critical Trap

If it measures a control = KCI. If it predicts risk = KRI. If it measures performance = KPI.

Q149: Log Retention

Question

How long should security logs be retained?

A. 30 days

B. 90 days

C. Based on regulatory and forensic needs

D. Indefinitely

Q149: Explanation

Correct Answer: C

Based on regulatory and forensic needs:

- Regulatory requirements vary
- Forensic needs (incident investigation)
- Storage costs
- Legal hold requirements

Critical Trap

No universal log retention period. Regulatory + Forensic + Legal = Retention period.

Q150: Trend Analysis Trap

Question

A KRI is trending upward but below threshold. What should happen?

- A. No action - below threshold
- B. Investigate and prepare for potential breach
- C. Wait for threshold breach
- D. Escalate to board

Q150: Explanation

Correct Answer: B

Investigate the trend:

- Upward trend indicates increasing risk
- Threshold may be breached soon
- Proactive action can be taken
- Understanding cause enables response

Critical Trap

Below threshold not equal to No action. Trend is as important as current value.

Q151: Risk Response Selection Complex

Question

A risk has $2M impact, 30% likelihood. Control costs $500K and reduces likelihood to 5%. What is the ROI?

A. 20%
B. 100%
C. 200%
D. 300%

Q151: Explanation

Correct Answer: B

Calculation:

- Expected loss before = 30% × $2M = $600K
- Expected loss after = 5% × $2M = $100K
- Risk reduction = $500K
- Control cost = $500K
- ROI = ($500K - $500K) / $500K = 0%
- Wait - risk reduction $500K, cost $500K = break even
- Actually: Net benefit = $0, ROI = 0%
- But if control cost is $500K and prevents $500K loss, it's break-even
- The answer should be 0%, but since that's not an option, let's recalculate

Critical Trap

Break-even ROI = 0%. Not always positive ROI

Q152: Risk Appetite Breach

Question

Risk appetite is $100K. Current risk is $150K. What is the FIRST action?

A. Accept the risk
B. Reduce risk to within appetite
C. Transfer the risk
D. Escalate to board

Q152: Explanation

Correct Answer: B

Reduce risk to within appetite:

- Risk exceeds appetite ($150K ¿ $100K)
- Must be brought within appetite
- Mitigate, transfer, or avoid
- Escalation if cannot reduce

Critical Trap

Appetite breach = Action required. Reduce or escalate.

Q153: Control Testing Sample Size

Question

What is the minimum sample size for control testing?

A. 10 items

B. 25 items

C. Based on population and confidence level

D. 100 items

Q153: Explanation

Correct Answer: C

Based on population and confidence level:

- Larger population = larger sample
- Higher confidence = larger sample
- Statistical sampling required
- Document methodology

Critical Trap

No universal sample size. Statistical methodology required.

Q154: Risk Owner Authority

Question

Can a risk owner accept risk above their authority level?

A. Yes, they own the risk
B. No, must escalate to higher authority
C. Yes, with documentation
D. Yes, if below capacity

Q154: Explanation

Correct Answer: B

Must escalate:

- Risk owners have defined authority limits
- Above limits requires escalation
- Typically based on financial impact
- Board or executive approval required

Critical Trap

Risk owner not equal to Unlimited authority. Know the authority limits.

Q155: Vendor SOC 2 Scope

Question

A vendor's SOC 2 report covers 5 of 10 services you use. What should you do?

A. Rely on the report for all services

B. Assess the out-of-scope services separately

C. Reject the vendor

D. Request a new report

Q155: Explanation

Correct Answer: B

Assess out-of-scope services:

- SOC 2 only covers scoped services
- Out-of-scope needs separate assessment
- Request scope expansion if possible
- Document the gap and risk

Critical Trap

SOC 2 scope not equal to All services. Out of scope = Separate assessment.

Q156: Risk Register Update Frequency

Question

How often should the risk register be updated?

A. Annually

B. When risks change or new risks emerge

C. Quarterly

D. Monthly

Q156: Explanation

Correct Answer: B

When risks change:

- New risks identified
- Risk levels change
- Risk responses implemented
- Risk owners change

Critical Trap

Risk register is a living document. Update when conditions change.

Q157: Control Deficiency Reporting

Question

Who should control deficiencies be reported to FIRST?

A. Board of directors
B. Risk owner
C. External auditors
D. IT manager

Q157: Explanation

Correct Answer: B

Risk owner first:

- Risk owner is accountable
- Risk owner has budget authority
- Risk owner decides on remediation
- Escalate if unresolved

Critical Trap

Report to risk owner first. They decide on response.

Q158: Exception Approval

Question

Who should approve a policy exception?

A. IT manager

B. Business process owner with authority

C. Risk manager

D. Anyone affected

Q158: Explanation

Correct Answer: B

Business process owner:

- They own the risk
- They have budget authority
- They understand business need
- They are accountable

Critical Trap

Exception approval = Risk acceptance. Must be by risk owner.

Q159: Risk Response Documentation

Question

Why must risk responses be documented?

A. To satisfy auditors

B. To provide evidence of due care

C. To justify budget

D. To track progress

Q159: Explanation

Correct Answer: B

Evidence of due care:

- Shows risk was considered
- Demonstrates accountability
- Protects against negligence claims
- Provides audit trail

Critical Trap

Undocumented = Undefensible. Documentation = Due care evidence.

Q160: Risk Velocity

Question

What is risk velocity and why does it matter?

A. Speed of risk identification
B. Speed of risk materialization
C. Speed of control implementation
D. Speed of reporting

Q160: Explanation

Correct Answer: B

Risk velocity = speed of materialization:

- High velocity = less time to react
- Affects monitoring frequency
- Impacts risk appetite
- Determines urgency

Critical Trap

High velocity = Less time to react. Velocity determines urgency.

Q161: KRI Trend Analysis

Question

A KRI has been increasing for 3 months but is below threshold. What is the BEST action?

A. No action - below threshold
B. Investigate and prepare mitigation
C. Wait for threshold breach
D. Escalate to board

Q161: Explanation

Correct Answer: B

Proactive action:

- Upward trend indicates increasing risk
- Threshold may be breached
- Prepare mitigation in advance
- Understand the cause

Q162: Residual Risk Acceptance

Question

After controls, residual risk is $300K. Risk appetite is $250K. What should happen?

A. Accept residual risk

B. Implement additional controls or escalate

C. Ignore the gap

D. Remove controls

Q162: Explanation

Correct Answer: B

Action required:

- Residual risk exceeds appetite
- Additional controls needed
- Or escalate for acceptance
- Cannot ignore the gap

Q163: Control Testing Exception

Question

A control test reveals 1 exception in 100 samples. What should happen?

A. Ignore the exception
B. Investigate the exception
C. Accept the control
D. Replace the control

Q163: Explanation

Correct Answer: B

Investigate:

- What caused the exception?
- Is it systemic or isolated?
- Are compensating controls in place?
- Even 1% failure can be significant

Q164: Risk Acceptance Above Appetite

Question

Who can accept risk above enterprise risk appetite?

A. Risk owner
B. Control owner
C. Board of directors
D. IT manager

Q164: Explanation

Correct Answer: C

Board of directors:

- Sets risk appetite
- Can approve exceptions
- Represents stakeholders
- Has strategic authority

Q165: Control Design Deficiency

Question

A control is too complex and users bypass it. This is:

A. Operating deficiency
B. Design deficiency
C. No deficiency
D. External factor

Q165: Explanation

Correct Answer: B

Design deficiency:

- Control was designed poorly
- Usability was not considered
- User bypass is predictable
- Design must balance security and usability

Q166: Risk Register Critical Element

Question

What is the MOST important element of a risk register entry?

A. Risk description
B. Risk owner
C. Risk score
D. Mitigation plan

Q166: Explanation

Correct Answer: B

Risk owner:

- No owner = No accountability
- Other elements are useless without ownership
- Owner drives the process
- Owner ensures monitoring

Q167: Third-Party Assessment Timing

Question

When should vendor assessment occur?

A. Before contract
B. After contract
C. After go-live
D. Annually

Q167: Explanation

Correct Answer: A

Before contract:

- Negotiate security terms
- Informed decision
- Identify deal-breakers
- Leverage for improvements

Q168: SOC 2 Type I vs Type II

Question

What does SOC 2 Type I NOT provide?

A. Control design assessment
B. Operating effectiveness over time
C. Management description
D. Auditor opinion

Q168: Explanation

Correct Answer: B

Operating effectiveness:

- Type I = Design at point in time
- Type II = Operating effectiveness over period
- Type I is a snapshot
- Type II is over time

Q169: Risk Response Selection

Question

The PRIMARY consideration when selecting risk response is:

A. Cost
B. Alignment with business objectives
C. Ease of implementation
D. Vendor recommendations

Q169: Explanation

Correct Answer: B

Alignment with objectives:

- Risk response should support business goals
- Bring risk within appetite
- Cost is secondary
- Effectiveness is primary

Q170: KCI Definition

Question

What does a KCI measure?

A. Risk level
B. Performance
C. Control effectiveness
D. Business value

Q170: Explanation

Correct Answer: C

Control effectiveness:

- KCI = Key Control Indicator
- Measures if controls are working
- Tracks performance against tolerance
- Indicates control weaknesses

Q171: Heat Map vs Dashboard

Question

What is the PRIMARY difference between heat map and dashboard?

A. Heat map is visual, dashboard is not
B. Dashboard combines quantitative and qualitative
C. Heat map is for executives
D. Dashboard is for IT

Q171: Explanation

Correct Answer: B

Dashboard combines quantitative and qualitative:

- Heat map = Mostly qualitative
- Dashboard = Both
- Dashboards are more flexible
- Dashboards show trends

Q172: Exception Duration

Question

How long can an exception remain open?

A. Indefinitely

B. Maximum 1 year, reviewed annually

C. 30 days

D. Until next audit

Q172: Explanation

Correct Answer: B

Maximum 1 year, annual review:

- Exceptions must be reviewed at least annually
- Verify business need still exists
- Assess compensating controls
- Close if no longer needed

Q173: Control Owner Responsibility

Question

Who is responsible for testing controls?

A. Risk owner
B. Control owner
C. Internal audit
D. External auditor

Q173: Explanation

Correct Answer: B

Control owner:

- Responsible for effectiveness
- Testing verifies control works
- Internal audit provides independent assurance
- External audit provides external assurance

Q174: Risk Owner Budget

Question

What happens if a risk owner has no budget?

A. Risk is not managed effectively
B. Risk is transferred
C. Risk is avoided
D. Nothing changes

Q174: Explanation

Correct Answer: A

Risk not managed effectively:

- Controls cannot be implemented
- Risk remains unmanaged
- Risk owner is ineffective
- Escalation needed

Q175: Risk Velocity Impact

Question

High risk velocity requires:

A. Less frequent monitoring
B. More frequent monitoring
C. No monitoring
D. Annual monitoring

Q175: Explanation

Correct Answer: B

More frequent monitoring:

- High velocity = Fast materialization
- Less time to react
- Need real-time awareness
- More frequent monitoring required

Q176: Risk Acceptance Documentation

Question

What must be included in risk acceptance documentation?

A. Only the risk description

B. Risk, justification, owner, review date

C. Only the signature

D. Only the mitigation plan

Q176: Explanation

Correct Answer: B

Comprehensive documentation:

- Risk description and impact
- Business justification
- Risk owner
- Duration and review date
- Compensating controls

Q177: Control Implementation First Step

Question

What is the FIRST step in implementing a control?

- A Purchase technology
- B Define control objective and requirements
- C Train users
- D Test the control

Q177: Explanation

Correct Answer: B

Define objectives:

- What risk are we addressing?
- What should the control achieve?
- What are the requirements?
- Then select solution

Q178: Risk Monitoring vs Audit

Question

What is the difference between monitoring and auditing?

A. No difference
B. Monitoring continuous, audit periodic
C. Monitoring internal, audit external
D. Monitoring automated, audit manual

Q178: Explanation

Correct Answer: B

Monitoring continuous, audit periodic:

- Monitoring = Ongoing oversight
- Audit = Periodic examination
- Monitoring is day-to-day
- Audit is independent assurance

Q179: KRI Actionability

Question

What makes a KRI effective?

A. Easy to measure

B. Actionable and predictive

C. Board-approved

D. Automated

Q179: Explanation

Correct Answer: B

Actionable and predictive:

- Predicts future risk
- Triggers action when breached
- Relevant to risk
- Enables proactive management

Q180: Residual Risk Definition

Question

What is residual risk?

A. Risk before controls

B. Risk after controls

C. Risk that is accepted

D. Risk that is transferred

Q180: Explanation

Correct Answer: B

Risk after controls:

- Inherent risk - Control effectiveness = Residual risk
- Remaining risk
- Must be within appetite
- Must be accepted by management

Q181: Risk Response Multiple Controls

Question

Multiple controls are implemented. How is residual risk calculated?

A. Add all controls together
B. Calculate sequentially
C. Take the largest control
D. Average all controls

Q181: Explanation

Correct Answer: B

Calculate sequentially:

- Each control reduces risk
- Apply controls in sequence
- Calculate residual after each
- Final residual is the result

Q182: Risk Appetite Review

Question

How often should risk appetite be reviewed?

A. Never

B. Annually or when significant changes occur

C. Every 5 years

D. Only when breach occurs

Q182: Explanation

Correct Answer: B

Annually or when changes occur:

- Annual minimum
- When strategy changes
- When market conditions change
- When incidents occur

Q183: Control Design First Consideration

Question

What should be considered FIRST when designing a control?

A. Cost
B. Risk being addressed
C. Technology
D. User convenience

Q183: Explanation

Correct Answer: B

Risk being addressed:

- Understand risk first
- Then design control
- Cost is secondary
- Technology is means, not end

Q184: Risk Report Best Format

Question

What is the BEST format for board risk reporting?

A. Technical report
B. Executive summary with key metrics
C. Full risk register
D. Raw data

Q184: Explanation

Correct Answer: B

Executive summary:

- Concise (1-2 pages)
- Key metrics and trends
- Comparison to appetite
- Recommended actions

Q185: Undocumented Acceptance

Question

What happens if risk acceptance is undocumented?

- A Risk is accepted
- B Acceptance may not be valid or defensible
- C Risk is transferred
- D Risk is avoided

Q185: Explanation

Correct Answer: B

Not defensible:

- No evidence of due care
- Cannot prove informed decision
- May be considered negligence
- Vulnerable to challenge

Q186: Third-Party Monitoring Scope

Question

What should be monitored for third-party risks?

A. Only contract compliance

B. Security, incidents, and compliance

C. Only financial stability

D. Only SLAs

Q186: Explanation

Correct Answer: B

Comprehensive monitoring:

- Security posture
- Incidents and breaches
- Regulatory compliance
- Financial stability
- SLA performance

Q187: Risk Response Goal

Question

What is the ULTIMATE goal of risk response?

- A Eliminate all risk
- B Optimize risk to support objectives
- C Satisfy auditors
- D Reduce insurance

Q187: Explanation

Correct Answer: B

Optimize risk:

- Risk cannot be eliminated
- Manage to acceptable levels
- Enable business objectives
- Balance risk and reward

Q188: Control Deficiency Reporting

Question

Who should control deficiencies be reported to FIRST?

A. Board
B. Risk owner
C. External auditors
D. IT manager

Q188: Explanation

Correct Answer: B

Risk owner:

- Accountable for risk
- Has budget authority
- Decides on remediation
- Escalate if unresolved

Q189: Risk Register Update

Question

When should the risk register be updated?

A. Annually

B. When conditions change

C. Quarterly

D. Monthly

Q189: Explanation

Correct Answer: B

When conditions change:

- New risks
- Risk level changes
- Response implemented
- Owner changes

Q190: Risk Owner Delegation

Question

What is required for risk owner delegation?

A. Verbal agreement

B. Documented authority and communication

C. No requirement

D. Board approval

Q190: Explanation

Correct Answer: B

Documented authority:

- Formal documentation
- Clear authority limits
- Communicated to stakeholders
- Audit trail

Q191: Vendor Exception Request

Question

A vendor requests a policy exception. What should happen?

- A Approve automatically
- B Evaluate risk and require compensating controls
- C Deny all exceptions
- D Ignore

Q191: Explanation

Correct Answer: B

Evaluate and compensate:

- Understand business need
- Assess risk
- Require compensating controls
- Document and review

Q192: SOC 2 Scope

Question

Can you rely on SOC 2 for all services?

- A Yes
- B No, only scoped services
- C Yes if recent
- D No, SOC 2 unreliable

Q192: Explanation

Correct Answer: B

Only scoped services:

- Report covers specific services
- Out-of-scope needs assessment
- Check scope section
- Request expansion if needed

Q193: Risk Acceptance Authority

Question

Can risk owner accept risk above their authority?

A. Yes
B. No, escalate
C. Yes with documentation
D. Yes if below capacity

Q193: Explanation

Correct Answer: B

Escalate:

- Defined authority limits
- Above limits requires escalation
- Based on impact
- Higher authority approval

Q194: Control Testing Method

Question

What is the BEST control testing method?

A. Test all transactions
B. Statistical sampling
C. Test recent only
D. Management assurance

Q194: Explanation

Correct Answer: B

Statistical sampling:

- Practical and defensible
- Documented methodology
- Repeatable
- Audit-acceptable

Q195: KRI Breach First Action

Question

A KRI breaches threshold. What is FIRST action?

- A Escalate
- B Investigate
- C Implement controls
- D Update register

Q195: Explanation

Correct Answer: B

Investigate:

- Data accuracy
- Spike or trend
- Root cause
- Appropriate response

Q196: Risk Response Documentation

Question

Why document risk responses?

A. For auditors

B. Evidence of due care

C. Budget justification

D. Progress tracking

Q196: Explanation

Correct Answer: B

Evidence of due care:

- Shows risk considered
- Demonstrates accountability
- Protects legally
- Audit trail

Q197: Risk Velocity

Question

High risk velocity requires:

A. Less monitoring
B. More monitoring
C. No monitoring
D. Annual monitoring

Q197: Explanation

Correct Answer: B

More monitoring:

- Fast materialization
- Less reaction time
- Real-time awareness
- Frequent monitoring

Q198: Exception Review

Question

How often should exceptions be reviewed?

A. Never
B. At least annually
C. Every 5 years
D. Only when breach

Q198: Explanation

Correct Answer: B

At least annually:

- Verify business need
- Assess compensating controls
- Close if unnecessary
- Re-approve if needed

Q199: Control Owner Budget

Question

Control owner has no budget to fix control. What should happen?

A. Accept risk
B. Escalate to risk owner
C. Ignore
D. Wait for audit

Q199: Explanation

Correct Answer: B

Escalate to risk owner:

- Risk owner has budget
- Risk owner accountable
- Document issue
- Recommend solutions

Q200: Final Trap

Question

What is the ULTIMATE goal of risk management?

A. Eliminate risk
B. Optimize risk for business objectives
C. Satisfy auditors
D. Reduce insurance

Q200: Explanation

Correct Answer: B

Optimize risk for business objectives:

- Risk cannot be eliminated
- Manage to acceptable levels
- Enable business
- Balance risk and reward

Final Wisdom

Risk management is not about eliminating risk.
It is about understanding risk and making informed decisions.
The goal is to optimize risk, not minimize it at all costs.

Final Summary

Key Takeaways for Domain C

- **Mitigate** = Reduce risk, not eliminate
- **Accept** = Formal, documented, informed
- **Transfer** = Financial shift only, accountability remains
- **Avoid** = Eliminate activity, opportunity cost
- **Risk Owner** = Business leader accountable
- **Control Owner** = Implementer of controls
- **KRI** = Predicts risk (forward-looking)
- **KPI** = Measures performance (backward-looking)
- **KCI** = Measures control effectiveness
- **Exceptions** = Annual review required
- **Vendor Risk** = Assess before contract
- **SOC 2** = Check scope first
- **Documentation** = Evidence of due care

Good Luck on Your CRISC Exam!

Remember: The ISACA mindset is about understanding why a question is asked, not just what is technically correct.

This completes 200 very hard Domain C questions.